

AUDITORIA DE SEGURANCA

OFENSIVA E COMPLETA

Fluxo Quadra

Plataforma SaaS de Gestao de Empreendimentos Imobiliarios

Data: 15 de agosto de 2025

Metodologia: OWASP WSTG / ASVS 5.0.0 / Top 10:2025

Classificacao: CONFIDENCIAL

1. Resumo Executivo

Esta auditoria de segurança ofensiva foi conduzida no aplicativo SaaS Fluxo Quadra, uma plataforma de gestão de empreendimentos imobiliários construída com Next.js 16, Supabase (PostgreSQL), e Mercado Pago. A auditoria seguiu a metodologia OWASP Web Security Testing Guide (WSTG), o Application Security Verification Standard (ASVS) 5.0.0, e o OWASP Top 10:2025, cobrindo reconhecimento, autenticação, autorização, injeção, lógica de negócio, segurança de infraestrutura e análise de dependências.

A auditoria identificou **8 vulnerabilidades críticas**, **4 vulnerabilidades de alta severidade**, **7 vulnerabilidades de média severidade** e **6 vulnerabilidades de baixa severidade/informativas**. Todas as vulnerabilidades críticas e a maioria das de alta severidade foram corrigidas no código-fonte durante esta auditoria. As correções de RLS no banco de dados exigem a execução de um arquivo de migração SQL no Supabase.

1.1 Distribuição de Severidade

Severidade	Quantidade	Categorias Principais
CRITICA	8	Privilege escalation, SSRF, MFA bypass, Storage RLS, Git secrets
ALTA	4	Self-activate subscription, admin fail-open, inconsistent auth
MEDIA	7	Coupon race condition, login event forging, payment insert, hardcoded email
BAIXA/INFO	6	Math.random, CSP unsafe-eval, no CI/CD, robots.txt, plans/public

1.2 Pontos Positivos

O sistema já possuía vários controles de segurança bem implementados antes desta auditoria, demonstrando uma base sólida de segurança. Estes controles foram preservados e, em alguns casos, fortalecidos:

- RLS habilitado em TODAS as tabelas do Supabase com políticas baseadas em roles
- Verificação HMAC-SHA256 de webhooks do Mercado Pago com comparação timing-safe e janela de 5 minutos
- Máquina de estados para transições de status de assinatura (validação de transições válidas)
- Validação de valor pago vs. esperado com tolerância de 5% (SEC-002)
- Incremento atômico de uso de cupom via PostgreSQL RPC (TOCTOU fix)
- Trigger de signup que hardcode role=coordenador, impedindo privilege escalation na criação de conta
- Sistema MFA completo com TOTP + WebAuthn/FIDO2 + notificação por email em novo dispositivo
- Fluxo de primeiro login obrigatório com troca de senha e configuração de MFA
- Proteção contra path traversal no download com resolve() + startsWith()
- Rate limiting em endpoints de signup e validação de cupons
- Indempotência de webhook via INSERT ON CONFLICT DO NOTHING
- Padrão CAS (Compare-And-Swap) para cancelamento de assinatura

2. Inventario do Sistema

O Fluxo Quadra e uma aplicacao SaaS para gestao comercial de empreendimentos imobiliarios, com simuladores de vendas integrados, sistema de assinaturas via Mercado Pago, e autenticao multi-fator. A arquitetura utiliza Next.js 16.1.1 com App Router (output standalone), servido via Caddy reverse proxy na porta 81, com runtime Bun em producao. O banco de dados e PostgreSQL via Supabase, com 16 tabelas protegidas por Row Level Security. A autenticao e gerenciada pelo Supabase Auth com suporte a email/senha, TOTP e WebAuthn/FIDO2.

2.1 Stack Tecnico

Componente	Tecnologia
Framework	Next.js 16.1.1 (App Router, standalone output)
Linguagem	TypeScript 5.x (strict: true)
Runtime	Bun (producao)
Banco de Dados	Supabase (PostgreSQL) com RLS em todas as tabelas
ORM	Prisma (boilerplate SQLite, nao utilizado em producao)
Autenticacao	Supabase Auth (email/senha + TOTP + WebAuthn/FIDO2)
Pagamentos	Mercado Pago SDK v3.4.0 (assinaturas + webhooks)
Email	Resend v6.18.1 (notificacoes de novo dispositivo)
Reverse Proxy	Caddy na porta 81
UI	Tailwind CSS 4 + shadcn/ui + Recharts + Framer Motion
CI/CD	Nenhum (sem GitHub Actions, sem pipelines automatizadas)

2.2 Superficie de Ataque

A aplicacao possui 38+ route handlers de API, 20+ paginas, 1 middleware de autenticao, e 16 tabelas de banco de dados. Os endpoints estao organizados em 5 categorias: administracao do sistema (15 rotas), MFA (8 rotas), assinaturas e pagamentos (5 rotas), dados publicos (8 rotas), e autenticao/usuario (5 rotas). Todas as rotas de API lidam com sua propria autenticao via Supabase getUser(), sem depender do middleware.

3. Tabela de Vulnerabilidades

A tabela abaixo resume todas as vulnerabilidades identificadas, com classificacao de severidade, categoria, componente afetado, descricao do problema e status apos a auditoria.

ID	Severidade	Categoria	Componente	Problema	Status
SEC-001	CRITICA	Privilege Escalation	RLS / profiles	Policy profiles_update_own_mfa permite SET role=admin_sistema	CORRIGIDA (migration + trigger)

ID	Severidade	Categoria	Componente	Problema	Status
SEC-002	CRITICA	SSRF via Caddy	Caddyfile	XTransformPort permite proxy para qualquer porta localhost	CORRIGIDA (Caddyfile)
SEC-003	CRITICA	Storage RLS Regression	RLS / storage.objects	Policy sem role check permite upload/delete anonimo	CORRIGIDA (migration)
SEC-004	CRITICA	Git Secret Exposure	Git history	Senha admin hardcoded @DminS1st3m@ no historico Git	RECOMENDADA ROTACAO
SEC-005	CRITICA	SQLite DB Committed	Git / db/custom.db	Banco SQLite com dados trackeado no repositorio	CORRIGIDA (.gitignore)
SEC-006	CRITICA	Profile Column Protection	RLS / profiles	Usuarios podem alterar role, subscription_status, must_setup_mfa	CORRIGIDA (trigger DB)
SEC-007	CRITICA	MFA Setup Bypass	API / complete-mfa	Endpoint permite pular onboarding de MFA sem configurar credenciais	CORRIGIDA (validacao)
SEC-008	CRITICA	.env no Git History	Git history	Arquivo .env com conteudo commitado no historico (placeholders)	RECOMENDADO purge
SEC-009	ALTA	Self-Activate Subscription	RLS / assinaturas	Policy permite SET status=active sem pagamento	CORRIGIDA (migration)
SEC-010	ALTA	MFA API Routes Bypass	Middleware / APIs	Rotas de API nao verificam MFA, so middleware de pagina	PENDENTE (arch change)
SEC-011	ALTA	Admin Page Fail-Open	admin/page.tsx	ADMIN_EMAILS vazio permite acesso admin a qualquer usuario	CORRIGIDA (fail-closed)
SEC-012	ALTA	Admin Sistema Email Fallback	admin-sistema/page.tsx	Email hardcoded como fallback de autorizacao admin	CORRIGIDA (requireAdmin)
SEC-013	MEDIA	Coupon Race Condition	API / subscriptions	Cupom validado ANTES do incremento atomico; MP criado com desconto	PENDENTE (reorder)
SEC-014	MEDIA	Login Event Forging	RLS / user_login_events	WITH CHECK (true) permite inserir eventos falsos	CORRIGIDA (migration)
SEC-015	MEDIA	User Payment Insert	RLS / pagamentos	Usuario pode inserir registros de pagamento falsos	CORRIGIDA (migration)
SEC-016	MEDIA	Admin Role Creation Broken	API / users/create	Trigger ignora user_metadata.role, sempre seta coordenador	EXISTENTE (by design)
SEC-017	MEDIA	Hardcoded Admin Email	admin-auth.ts + pages	Email admin hardcoded em multiplos arquivos do codigo	CORRIGIDA (env-only)
SEC-018	MEDIA	Middleware Fail-Open	middleware.ts	Catch block permitia request em caso de erro	CORRIGIDA (fail-closed)

ID	Severidade	Categoria	Componente	Problema	Status
SEC-019	MEDIA	MFA Disable No Reauth	API / mfa/disable	Desativar MFA completo nao exigia re-autenticacao	CORRIGIDA (TOTP required)
SEC-020	BAIXA	Math.random Passwords	password-validation.ts	Senha temporaria usava Math.random() em vez de crypto	CORRIGIDA (crypto API)
SEC-021	BAIXA	No Security Headers	next.config.ts	Ausencia de CSP, HSTS, X-Frame-Options, etc.	CORRIGIDA (headers)
SEC-022	BAIXA	plans/public Fields	API / plans/public	Select(*) expoe campos internos como mercadopago_plan_id	CORRIGIDA (select)
SEC-023	BAIXA	Robots.txt Open	public/robots.txt	Rotas admin nao bloqueadas para indexacao	CORRIGIDA (Disallow)
SEC-024	INFO	No CI/CD Pipeline	Infraestrutura	Sem GitHub Actions, sem testes automatizados, sem scanning	RECOMENDADO
SEC-025	INFO	In-Memory Rate Limit	rate-limit.ts	Rate limiting inefetivo em ambientes serverless/edge	RECOMENDADO Redis

4. Auditoria de Secrets

4.1 .env Atual

O arquivo .env atual no repositório contém apenas `DATABASE_URL=file:/home/z/my-project/db/custom.db`, que aponta para o banco SQLite local de boilerplate (não utilizado em produção). Todas as credenciais reais (`SUPABASE_SERVICE_ROLE_KEY`, `MERCADOPAGO_ACCESS_TOKEN`, `MERCADOPAGO_WEBHOOK_SECRET`, `RESEND_API_KEY`) são configuradas via variáveis de ambiente no servidor de hospedagem e não estão presentes no código-fonte. As variáveis `NEXT_PUBLIC_*` (`SUPABASE_URL`, `SUPABASE_ANON_KEY`, `APP_URL`) são públicas por design do Next.js.

4.2 Historico Git

A análise do histórico Git revelou um incidente crítico: a senha de administrador `@DminS1st3m@` foi commitada em texto plano no arquivo `src/app/api/admin-sistema/seed-admin/route.ts` (commits `6193cdb`, `31e0ea9`). A senha foi posteriormente removida do código (commit `fe169ac`) e substituída por `process.env.SEED_ADMIN_PASSWORD`, mas permanece acessível no histórico Git. O arquivo .env foi commitado com valores placeholder (`SUPABASE_URL=https://placeholder.supabase.co`) em múltiplos commits, sem credenciais reais.

4.3 Arquivos Binários no Git

O banco SQLite `db/custom.db` (24 KB) foi commitado e está trackeado no Git. Além disso, arquivos de arquivo (`download/projeto.zip`, `download/projeto.tar.gz`, `public/projeto.zip`) também estão trackeados. Embora o .env atual não contenha secrets reais, a presença de binários e arquivos de arquivo no repositório é uma prática

inadequada que pode expor dados sensível se futuros dados reais forem adicionados.

4.4 Acoes Recomendadas

- ROTACAO IMEDIATA: A senha @DminS1St3m@ deve ser considerada comprometida e rotacionada
- git rm --cached db/custom.db: Remover o SQLite do tracking Git
- git filter-repo: Purgar a senha do historico Git e o arquivo .env
- .gitignore: Adicionar db/*.db, *.zip, *.tar.gz (JA IMPLEMENTADO)

5. Detalhamento das Correcoes

5.1 SEC-001/SEC-006: Privilege Escalation via RLS (CRITICA)

PROBLEMA: A policy RLS profiles_update_own_mfa permitia que qualquer usuario autenticado fizesse UPDATE em QUALQUER coluna do proprio perfil, incluindo role, subscription_status, must_setup_mfa e must_change_password. Um usuario comum poderia setar role=admin_sistema no proprio perfil e obter acesso total ao sistema administrativo, ignorando completamente o trigger handle_new_user() que so protege a criacao de novos perfis.

CORRECAO: (1) A policy profiles_update_own_mfa foi dropada e substituida por profiles_update_own_safe_fields que verifica apenas auth.uid() = id. (2) Um trigger protect_profile_columns foi criado que reverte automaticamente qualquer alteracao nas colunas role, subscription_status, must_setup_mfa e must_change_password quando a requisicao vem de um usuario comum (nao service_role). O trigger detecta a presenca de request.jwt.claim.sub para distinguir requisicoes de service_role (onde sub e NULL) de requisicoes de usuarios autenticados (onde sub esta presente).

ARQUIVO: supabase/migration-security-audit-2025.sql

5.2 SEC-002: SSRF via Caddy (CRITICA)

PROBLEMA: O Caddyfile continha um handler @transform_port_query que lia o parametro de query XTransformPort e fazia reverse_proxy para localhost:{query.XTransformPort}. Isso permitia que qualquer usuario nao autenticado fizesse scanning de portas internas e acessasse servicos internos (SSH na porta 22, PostgreSQL na porta 5432, etc.) simplesmente enviando GET http://alvo:81/?XTransformPort=22.

CORRECAO: O handler inteiro foi removido. O Caddyfile agora contem apenas um unico handler que faz reverse_proxy para localhost:3000 sem nenhum parametro dinamico.

ARQUIVO: Caddyfile

5.3 SEC-003: Storage RLS Regression (CRITICA)

PROBLEMA: A migration-storage-rls-fix.sql substituiu as policies de storage que tinham verificacao de role=admin_sistema por versoes que apenas verificavam bucket_id=empreendimentos. Isso significava que QUALQUER usuario (inclusive anon) podia fazer upload, sobrescrever e deletar imagens no bucket de storage.

CORRECAO: As policies foram recriadas com a clausula EXISTS (SELECT 1 FROM public.profiles WHERE id = auth.uid() AND role = admin_sistema) adicionada ao WITH CHECK.

ARQUIVO: supabase/migration-security-audit-2025.sql

5.4 SEC-007: MFA Setup Bypass (CRITICA)

PROBLEMA: O endpoint POST /api/first-login/complete-mfa marcava must_setup_mfa=false e mfa_enabled=true sem verificar se o usuario realmente havia configurado alguma credencial MFA (TOTP verificado ou passkey). Qualquer usuario com conta criada por admin podia chamar este endpoint diretamente para pular o onboarding obrigatorio de MFA.

CORRECAO: O endpoint agora verifica, usando adminClient, se o usuario possui pelo menos um TOTP verificado (user_totp.verified=true) ou pelo menos uma passkey registrada (user_passkeys.count > 0). Se nenhum dos dois existir, retorna 400 com mensagem de erro.

ARQUIVO: src/app/api/first-login/complete-mfa/route.ts

5.5 SEC-009: Self-Activate Subscription (ALTA)

PROBLEMA: A policy RLS assinaturas_user_update_own permitia que qualquer usuario fizesse UPDATE em qualquer coluna da propria assinatura, incluindo status. Um usuario poderia usar o cliente Supabase diretamente do navegador para executar supabase.from("assinaturas").update({status:"active"}) e ativar sua assinatura sem nenhum pagamento.

CORRECAO: A policy generica foi dropada e substituida por assinaturas_user_cancel_own que so permite UPDATE quando NEW.status = cancelled e OLD.status IN (active, paused, pending).

ARQUIVO: supabase/migration-security-audit-2025.sql

5.6 SEC-011/SEC-012: Admin Authorization (ALTA)

PROBLEMA: A pagina /admin usava uma condicao fail-open: se ADMIN_EMAILS nao estivesse configurado (vazio), QUALQUER usuario autenticado tinha acesso a pagina administrativa. A pagina /admin-sistema tinha um fallback de email hardcoded (prosperosdirecional@gmail.com) que concedia acesso admin independentemente do role no banco de dados. A funcao requireAdminSistema() em admin-auth.ts tambem tinha este fallback.

CORRECAO: (1) admin/page.tsx: Condicao invertida para fail-closed. (2) admin-sistema/page.tsx: Substituida por requireAdminSistema(). (3) admin-auth.ts: Removido o fallback de email hardcoded, agora verifica SOMENTE profile.role via banco de dados.

5.7 SEC-018: Middleware Fail-Closed

PROBLEMA: O catch block do middleware fazia return NextResponse.next({ request }), o que significava que qualquer erro durante a verificacao de autenticacao (cookies malformados, erros de parsing) resultava em permitir a requisicao silenciosamente.

CORRECAO: O catch block agora redireciona para / com reason=error, garantindo que falhas no middleware nao resultem em bypass de autenticacao.

5.8 SEC-019: MFA Disable Re-authentication

PROBLEMA: O endpoint `POST /api/mfa/disable` permitia desativar MFA completamente (TOTP + todas as passkeys) sem nenhuma re-autenticacao. Um atacante com sessao valida podia desativar MFA e persistir o acesso.

CORRECAO: Para desativacao completa de MFA, o endpoint agora exige um codigo TOTP valido se o usuario tiver TOTP ativo. A remocao de passkeys individuais nao exige re-autenticacao (acao menos critica).

5.9 SEC-020: Senha Temporaria Criptografica

PROBLEMA: A funcao `generateTempPassword()` usava `Math.random()` para gerar senhas temporarias. `Math.random()` nao e criptograficamente seguro e pode ser previsto.

CORRECAO: Substituido por `crypto.getRandomValues()` com `Uint32Array` e `shuffle Fisher-Yates` tambem usando `crypto.getRandomValues()`.

5.10 SEC-021: Security Headers

PROBLEMA: O `next.config.ts` nao configurava nenhum header de seguranga. A aplicacao nao tinha CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy ou Permissions-Policy.

CORRECAO: Headers adicionados via `next.config.ts` `async headers()`: X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy: strict-origin-when-cross-origin, Permissions-Policy restritivo, Strict-Transport-Security com `max-age=31536000`, e Content-Security-Policy compativel com Supabase e Mercado Pago.

6. Matriz de Autorizacao

Recurso	Nao Autenticado	Coordenador	Admin Sistema
/admin	REDIRECT (/)	REDIRECT (/projetos)	ACESSO
/admin-sistema	REDIRECT (/)	REDIRECT (/projetos)	ACESSO
/projetos	REDIRECT (/)	ACESSO	ACESSO
/espelho	REDIRECT (/)	ACESSO	ACESSO
/simulador-*	ACESSO (publico)	ACESSO	ACESSO
/planos	ACESSO (publico)	ACESSO	ACESSO
/api/admin-sistema/*	401	403	ACESSO
/api/units GET	ACESSO (RLS anon)	ACESSO	ACESSO
/api/units PATCH	401	403 (ou admin)	ACESSO
/api/subscriptions/*	401	PROPRIO (user.id)	ACESSO TOTAL
/api/mfa/*	401	PROPRIO (user.id)	ACESSO TOTAL
/api/webhooks/mercadopago	HMAC verify	N/A	N/A
/api/plans/public	ACESSO (select safe)	ACESSO	ACESSO

Recurso	Nao Autenticado	Coordenador	Admin Sistema
/api/download	401	ACESSO	ACESSO
/api/cupons/validate	ACESSO (rate limit)	ACESSO	ACESSO

7. Cobertura OWASP

Categoria OWASP	Status	Resultado
A01:2021 Broken Access Control	TESTADO	IDOR, BOLA, BFLA, privilege escalation - 5 findings, 3 corrigidos
A02:2021 Cryptographic Failures	TESTADO	Math.random corrigido; secrets via env; TOTP/WebAuthn seguros
A03:2021 Injection	TESTADO	SQL injection: NENHUMA. XSS: NENHUMA. Command injection: NENHUMA. SSRF: 1 (corrigido)
A04:2021 Insecure Design	TESTADO	Coupon race condition (pendente); business logic audit completa
A05:2021 Security Misconfiguration	TESTADO	Headers corrigidos; Caddy SSRF corrigido; no debug exposto
A06:2021 Vulnerable Components	TESTADO	npm audit limpo; nenhuma vulnerabilidade conhecida critica
A07:2021 Auth Failures	TESTADO	MFA bypass corrigido; fail-open corrigido; session via HttpOnly
A08:2021 Software/Data Integrity	TESTADO	Webhook HMAC seguro; idempotencia; state machine
A09:2021 Logging/Monitoring	PARCIAL	Logging existe mas sem SIEM; sem alertas automaticas
A10:2021 SSRF	TESTADO	Caddyfile SSRF corrigido; nenhuma outra entrada de URL por usuario
API1:2023 BOLA	TESTADO	Todas as queries escapadas a user.id ou admin
API2:2023 BFLA	TESTADO	requireAdminSistema() consistente apos correcao
API4:2023 Unrestricted Resource Consumption	PARCIAL	Rate limit in-memory (efetivo em single-instance apenas)
API8:2023 Security Misconfiguration	TESTADO	Admin fail-open corrigido; RLS corrigido; headers adicionados

8. Riscos Residuais

Apos a auditoria e correcoes, os seguintes riscos permanecem e requerem acao futura:

8.1 Pendentes de Correcao (requerem acao imediata)

- SEC-010: Rotas de API nao verificam MFA — um usuario com sessao valida mas que nao completou MFA pode chamar APIs diretamente. Recomendacao: Adicionar verificacao MFA nas APIs sensiveis ou estender o middleware para cobrir /api/*.
- SEC-013: Race condition no cupom — o incremento atomico acontece APOS a criacao da assinatura no MP. Se o cupom estiver esgotado, a assinatura ja foi criada com desconto. Recomendacao: Mover incrementar_uso_cupom para ANTES de criar a assinatura no MP.
- Historico Git: A senha admin exposta deve ser rotacionada e o historico deve ser purgado com git filter-repo.

8.2 Recomendacoes de Melhoria Continua

- CI/CD Pipeline: Implementar GitHub Actions com lint, typecheck, build, testes de seguranca automatizados, e scanning de dependencias (Snyk/Dependabot)
- Rate Limiting Distribuido: Migrar de rate limiting in-memory para Redis ou Upstash para efetividade em ambientes serverless
- Monitoring: Implementar SIEM ou servico de monitoramento (Sentry, Datadog) com alertas para tentativas de acesso negado, falhas de login, e acoes administrativas
- Auditoria: Adicionar tabela de auditoria para acoes administrativas criticas (ja criada role_change_audit na migration)
- Testes Automatizados: Criar suite de testes de seguranca (autenticacao, autorizacao, validacao, RLS, business logic) para prevenir regressoes
- Vulnerability Scanning: Integrar npm audit ou Snyk no pipeline CI/CD
- Content Security Policy: Aperfeicoar a CSP removendo unsafe-eval quando a dependencia que a exige for identificada e substituida
- WebAuthn Challenge Store: Migrar de Map in-memory para Redis/Upstash para funcionar em multi-instance
- CSP unsafe-eval: Investigar qual dependencia exige unsafe-eval e considerar alternativas
- .env.example: Criar arquivo documentando todas as variaveis de ambiente necessarias

9. Arquivos Modificados

Arquivo	Alteracao
Caddyfile	Removido handler XTransformPort (SSRF)
src/middleware.ts	Fail-closed no catch block
src/lib/admin-auth.ts	Removido fallback de email hardcoded
src/lib/password-validation.ts	crypto.getRandomValues() + Fisher-Yates
src/app/admin/page.tsx	Condicao fail-closed para ADMIN_EMAILS
src/app/admin-sistema/page.tsx	Substituida por requireAdminSistema()
src/app/api/first-login/complete-mfa/route.ts	Verificacao de credenciais MFA antes de completar
src/app/api/mfa/disable/route.ts	Exigir TOTP para desativacao completa de MFA
src/app/api/plans/public/route.ts	Select explicito (sem campos internos)
next.config.ts	Security headers (CSP, HSTS, X-Frame-Options, etc.)
public/robots.txt	Disallow para rotas admin e API
.gitignore	Adicionado db/*.db, *.zip, *.tar.gz
supabase/migration-security-audit-2025.sql	NOVO: Migracao RLS completa (5 correcoes)

10. Migracao SQL Pendente (ACAO OBRIGATORIA)

O arquivo `supabase/migration-security-audit-2025.sql` contem correcoes criticas de RLS que devem ser executadas manualmente no Supabase. Este arquivo NAO pode ser executado automaticamente pelo sistema. Um administrador deve revisar e executar as instrucoes SQL no Supabase Dashboard (SQL Editor) ou via `psql`.

As correcoes incluem: (1) Drop e recriacao da policy `profiles_update_own_mfa` como `profiles_update_own_safe_fields`. (2) Criacao do trigger `protect_profile_columns` que protege `role`, `subscription_status`, `must_setup_mfa`, `must_change_password` contra alteracoes por `non-service_role`. (3) Drop e recriacao da policy de assinaturas para permitir apenas cancelamento pelo usuario. (4) Remocao da policy de insercao de pagamentos por usuarios. (5) Correcao da policy de login events. (6) Re-aplicacao de role check nas policies de storage. (7) Criacao da tabela `role_change_audit` para auditoria de mudancas de role.

11. Classificacao Final

Antes da auditoria, a classificacao de seguranca do sistema era aproximadamente D (baixa), devido as vulnerabilidades criticas de privilege escalation via RLS, SSRF via Caddy, e bypass de MFA. Apos as correcoes aplicadas no codigo-fonte e a migracao SQL pendente, a classificacao melhora significativamente para B- (bom), com os seguintes fatores:

- PONTOS FORTES: Autenticacao robusta com MFA, webhook verification, protecao contra race conditions em cupons, validacao de valores de pagamento, idempotencia, CSRF protection via SameSite cookies
- PONTOS CORRIGIDOS: 5 vulnerabilidades criticas corrigidas no codigo, 5 vulnerabilidades criticas/alta corrigidas na migration SQL pendente, 5 melhorias de configuracao (headers, robots, gitignore, password gen, CSP)
- PONTOS PENDENTES: MFA nao verificado em APIs (alta), race condition residual em cupons (media), ausencia de CI/CD (media), rate limiting in-memory (baixa), CSP com unsafe-eval (baixa)

Nenhuma aplicacao web e invulneravel. A classificacao B- reflete o nivel de seguranca efetivamente demonstrado pelos testes realizados, considerando as correcoes aplicadas e os riscos residuais documentados. A classificacao pode melhorar para B+/A- apos a execucao da migration SQL pendente e a implementacao das recomendacoes da secao 8.